

NEXUS PENTEST - Instrukciya

1. USTANOVKA

Shag 1 - Ustanovit Python

Skachat s python.org, versiya 3.10 ili vyshe.

Pri ustanovke postavit galochku: Add Python to PATH

Shag 2 - Skachat programmu

Skachat fayly s GitHub ili poluchit napryamuyu.

Pologit vse tri faylya v odnu papku:

```
pentest_gui.py  
pentest_core.py  
exploit_engine.py
```

Shag 3 - Ustanovit zavisimosti

Otkryt cmd / PowerShell v papke s faylami i vypolnit:

```
pip install customtkinter requests httpx paramiko beautifulsoup4 lxml dnspython websocket-client
```

Shag 4 - Zapusk

```
python pentest_gui.py
```

Vozmozhnye oshibki:

- 'pip ne yavlyaetsya komandoy' -> python -m pip install ...
- 'python ne nayden' -> pereustanovit Python s galochkoy Add to PATH
- 'ModuleNotFoundError' -> pip install nazvanie_modulya

NEXUS PENTEST - Instrukciya

2. VKLADKA 'SKANIROVANIE'

1. Vvedi URL tseli: `http://localhost.tu`
2. Vyberi moduli v Nastroykakh
3. Nazhmi 'Zapustit skanirovanie'
4. Vnizu vidno log v realnom vremeni
5. Po zavershenii pokazhet: HIGH / MEDIUM / LOW nahodki

3. VKLADKA 'NAHODKI'

- Vse uyazvimosti otsortirovany po kritichnosti
- HIGH = krasnyy, MEDIUM = zheltyy, LOW = siniy
- Filtr: vvedi slovo (napr. `sqli` ili `xss`)
- Filtr po ugroze: VSE / HIGH / MEDIUM / LOW
- Klik na stroku -> poyavyatsya podrobnosti

PRAVYY KLIK na uyazvimost -> menju ataki:

`SQLi` -> Avto eksployt, Tablitsy, Versiya BD
`XSS` -> Cookie Stealer, Keylogger, Skaner portov
`LFI` -> Chtenie faylov, PHP ishodniki
`CMDi` -> Vypolnit komandu, Reverse Shell

Knopki HTML / JSON / TXT - eksport otcheta

4. VKLADKA 'ISTORIYA'

- Vse HTTP zaprosy kotorye delala programma
- Klik na zapros -> polnyy Request i Response
- Zveta: zelenyy 2xx, siniy 3xx, krasnyy 4xx, oranzhevyy 5xx

5. VKLADKA 'KODIROVSHCHIK'

1. Vstavit tekst
2. Vybrat tip: Base64, URL, HTML, Hex, MD5, SHA1, SHA256
3. Nazhat Kodirovit ili Dekodirovit
4. Skopirovat rezultat

6. VKLADKA 'EKSPLOYT'

SQLi Eksployt

1. Vvedi URL uyazvimoy stranitsy
2. Vvedi uyazvimyy parametr (napr. q)
3. Vyberi metod GET ili POST

Knopki:

```
Avto eksployt -> delaet vse avtomaticheski
Nayti stolbtisy -> opredelyaet kolichestvo stolbtsov
Versiya BD -> poluchaet versiyu MySQL
Polzovatel/BD -> tekushchiy polzovatel i baza
Tablitsy -> spisok vseh tablits
Stolbtisy -> vvedi tablitsu -> poluchi stolbtisy
Damp tablitsy -> vvedi tablitsu i stolbtisy -> vygr uzi
```

XSS Arsenal

1. Vvedi URL servera zahvata gde pridut dannye
2. Knopki generiruyut payloady:
 - Cookie Stealer: kradet kuki zhertvy
 - Keylogger: zapisyvaet nazhatiya klavish
 - Skaner portov: skaniruet set cherez brauzer
 - CSRF: otpravlyaet formu ot imeni zhertvy
3. Skopiruy payload i vnedriy v uyazvimyy parametr

LFI Chtenie

1. Vvedi URL i parametr (napr. page)
2. Knopki:

```
/etc/passwd -> spisok polzovateley sistemy
.env -> paroli BD i klyuchi
PHP ishodnik -> chitat PHP fayly cherez php://filter
Log Poisoning -> PHP shell v log -> komandyi
```

CMDi Vypolnenie

1. Vvedi URL i parametr
2. V pole Komanda vvedi chto vypolnit
3. Knopki: id/whoami, ls -la /, Reverse Shell

Reverse Shell:

1. Vvedi svoy IP i port
2. Zapusti: nc -lvnp 4444
3. Otpravit payload na server

Adminer Brutfors

1. Vvedi URL adminer.php
2. Vvedi servery, polzovateley, paroli (kazhdyy s novoy stroki)
3. Nazhat Zapustit -> vidish kazhdyu popytku
4. Pri nahodke: [!!!] VALID: server=... user=... password=...

Server zahvata

1. Nazhat Zapustit -> HTTP server na portu 7777
2. Skopiruy URL -> vstavit v XSS payload
3. Kogda zhertva otkroet stranits u s XSS -> dannye pridut

NEXUS PENTEST - Instrukciya

4. Nazhat Obnovit -> uvidit IP zhertvy, kuki, dannye form

NEXUS PENTEST - Instrukciya

7. VKLADKA 'BIZNES-LOGIKA'

IDOR Skaner

Proveryaet mozhno li poluchit chuzhie dannye menyaya ID:

1. URL: `http://localhost.tu/order?id=1`
2. Parametr: `id`
3. Diapazon: ot 1 do 100
4. Nazhat Skanirovat

Programma sravnivaet otvety - esli razmer otlichaetsya -> vozmozhnyy IDOR

Gonka zaprosov

Proveryaet uyazvimost odnoveremennykh zaprosov (Race Condition):

1. Vvedi URL i parametr
2. Kolichestvo potokov: 50-100
3. Nazhat Zapustit gonku
4. Esli otvety raznye -> vozmozhna uyazvimost

Manipulyatsiya tsenoy

Proveryaet korektnost obrabotki tsen:

1. URL korziny / oplaty
2. Parametr tseny (napr. price, amount)
3. Knopki testiruyut: -1, 0, 99999999, abc
4. Smotri otvet servera - prinyal li nekorrektnoye znachenie

Tsepochki eksptoytov

1. Snachala zapusti skanirovanie
2. Nazhat Analizirovat nahodki
3. Pokazhet gotovye tsepochki atak:

SQLi -> damp paroley -> vzlom kheshey -> vkhod kak admin
LFI + SQLi -> zapis shell -> vypolnenie komand
XSS + admin panel -> ugon sessii admina
CMDi -> reverse shell -> polnyy dostup

8. VKLADKA 'NASTROYKI'

Vklyuchi/vyklyuchi moduli skanirovaniya:

Zagolovki - proverka security headers
Puti - poisk skrytykh faylov
XSS - mezhsaytovyy skripting
SQLi - SQL in ektsii
LFI - vklyuchenie lokalnykh faylov
SSTI - in ektsii v shablony
CMDi - vypolnenie komand
Blind SQLi - medlennaya no glubokaya proverka

Kolichestvo potokov: bolshe = bystree, no zametno dlya servera

VAZHNOE PRIMECHANIE

Programma prednaznachena TOLKO dlya testirovaniya SOBSTVENNOGO servera.
Ispolzovanie protiv chuzhikh saytov nezakonne.